

C O D E R + C L A U D E C O D E · Q I N T E S S

Documento TO-BE (Ejecutivo)

Para: Jefaturas / Comité

De: Equipo DevSecOps — Qintess

Fecha: 2026-07-21

Estado: Visión aprobada + **piloto funcional validado end-to-end**

Piloto validado end-to-end

Documento interno · Plataforma de entornos de desarrollo con IA gobernada por rol

1. Resumen ejecutivo

Estamos construyendo una **plataforma de entornos de desarrollo con IA (Claude Code) gobernada por rol**: cada persona del banco recibe, con un solo login, un entorno de trabajo en el navegador (VS Code + terminal + Claude) que **solo puede hacer lo que su rol permite** — las herramientas, los accesos y las reglas de trabajo se ajustan automáticamente a si es Developer, QA o Architect.

El valor para el banco es triple:

- **Gobierno y seguridad**: cada operador ve y toca únicamente lo que le corresponde. La IA opera dentro de barreras definidas por rol, no "todo para todos".
- **Trazabilidad / auditoría**: quién hizo qué, con qué herramientas y sobre qué recursos queda registrado.
- **Productividad reproducible**: entornos idénticos, efímeros y listos en minutos — se acabó el "en mi máquina sí funciona".

Lo más importante para esta presentación: no es una idea en papel. **El piloto ya está funcionando y validado de punta a punta** (ver Sección 5).

2. Problema que resuelve

Los equipos que trabajan con IA generativa hoy enfrentan:

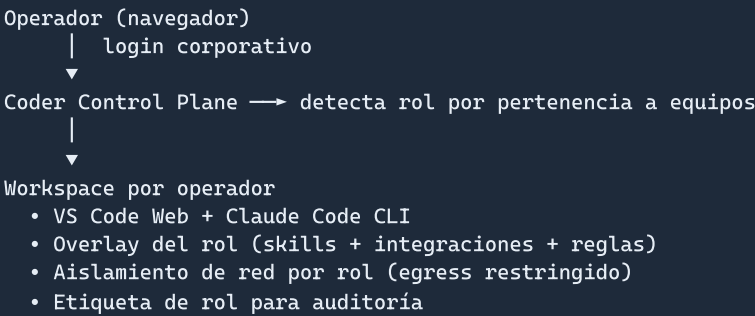
- **Sin gobierno**: cualquiera puede usar la IA con acceso total → riesgo para un entorno bancario (datos, repos, sistemas sensibles).
- **Sin trazabilidad**: no hay registro de qué hizo la IA ni con qué permisos.
- **Entornos inconsistentes**: cada quien configura su máquina distinto → errores, retrabajo, riesgo.
- **Onboarding lento**: montar un entorno seguro y completo toma días.

3. La solución (qué reciben los operadores)

Una plataforma basada en **Coder** (entornos de desarrollo self-hosted) donde:

1. El operador entra con **su cuenta corporativa** (hoy GitHub OAuth; en producción, el IdP del banco).
2. La plataforma **detecta su rol automáticamente** según su pertenencia a equipos.
3. Se le provisiona un **workspace en el navegador** ya configurado para su rol: VS Code web + Claude Code, con las **skills, integraciones (MCP) y reglas de trabajo** propias de Developer, QA o Architect.
4. Los accesos a repos, Jira/Confluence, etc. son **por identidad del usuario** — la IA solo alcanza lo que esa persona ya puede ver.

4. Arquitectura (visión de producción)



- **Model-agnostic:** Claude hoy; el diseño soporta cambiar de backend LLM (suscripción, Vertex AI, Bedrock) sin rehacer la plataforma.
- **Cloud-agnostic:** diseñado para Kubernetes en cualquier nube; se implementa en una.

5. Estado actual — ya funciona (piloto validado)

Todo lo siguiente está **implementado y probado end-to-end** en el entorno piloto:

Capacidad	Estado
Entornos Coder + VS Code + Claude Code en el navegador	✓ Funcionando
Login con cuenta corporativa (GitHub OAuth)	✓ Validado
RBAC: 3 roles (Developer, QA, Architect) detectados automáticamente	✓ Validado con cuentas reales
Cada rol recibe sus skills, integraciones y reglas propias	✓ Validado
Integración GitHub por usuario (solo ve sus repos)	✓ Aislamiento demostrado
Integración Jira + Confluence por usuario	✓ Conectado
Integración Playwright (pruebas automatizadas, rol QA)	✓ Conectado
Persistencia: los entornos sobreviven a reinicios del servidor	✓ Validado
Cambio de organización/cliente por configuración central	✓ Implementado

Prueba de aislamiento (el punto que más convence): dos usuarios reales con el mismo template ven cosas distintas según su identidad — un usuario ve sus 90 repositorios; otro, con acceso limitado, ve 0. La IA nunca excede el acceso de la persona.

6. Gobierno por rol (RBAC)

Recurso	Developer	QA	Architect
Skills habilitadas	Implementación, code review, frontend/UX	Generación de pruebas, cobertura, mutación, BDD	Revisión de arquitectura, specs
GitHub	Lectura/escritura	Lectura	Lectura
Jira / Confluence	Sí	Sí (crea bugs)	Sí + Confluence
Pruebas E2E (Playwright)	—	Sí	—
Reglas de trabajo (governance)	BDD-first, límites de alcance	Umbral de cobertura, calidad de tests	No-funcionales de banca (PCI, auditoría)

Política de permisos: en caso de pertenecer a varios equipos, gana el rol **menos permisivo** (principio de *least-privilege*, apropiado para banca).

Altas y bajas de acceso: las **degradaciones y salidas se aplican de inmediato** (se termina el entorno); las promociones toman efecto en el siguiente arranque. Diseñado para no dejar accesos residuales — punto clave para auditoría.

7. Roadmap de despliegue (piloto → producción, ~8 semanas)

Fase	Entregable
1	Desplegar plataforma + imagen base en infraestructura del banco
2	Integrar login corporativo + resolución de rol
3	Overlays por rol + aislamiento de red
4	5 early adopters
5–6	Feedback y ajustes
7	Rollout al squad completo (15–30 personas)
8	Revisión de métricas de adopción y gobierno

Del piloto a producción: el piloto corre en Docker (1 servidor); la versión de producción es la misma arquitectura sobre Kubernetes con el IdP del banco. El diseño de producción (`prod-oidc`) ya está preparado.

8. Riesgos y mitigaciones

Riesgo	Mitigación
Caída del proveedor de identidad	Acceso administrativo de emergencia
Consumo/costos de IA	Presupuesto por usuario + alertas + auto-apagado de entornos inactivos
Fuga de permisos (overlay desactualizado)	Reconstrucción automática de configuración por rol
Fuga de red (egress)	Aislamiento por defecto (deny-all) + auditoría periódica de políticas

9. Observabilidad y KPIs

Stack de monitoreo (Prometheus + Grafana + Loki) sobre 4 capas: auditoría de Coder, uso de Claude (tokens, herramientas), métricas de K8s y violaciones de gobierno.

KPIs de negocio: tasa de adopción · costo por usuario/día · **violaciones de gobierno** → 0 · tiempo de onboarding.

10. Qué pedimos a las jefaturas

- **Validación de la visión** y del enfoque de gobierno por rol para entornos con IA.
- **Sponsor** para pasar del piloto (ya funcionando) a un despliegue sobre infraestructura del banco.
- Definir el **grupo de early adopters** (5 personas) para la primera fase.

Anexo — Documentación técnica de respaldo

El detalle técnico completo vive en [docs/T0-BE/](#) (14 documentos): arquitectura, RBAC y mapping de roles, template Terraform, skills/MCP por rol, aislamiento de red, imagen base, observabilidad, gestión de secretos, OAuth por usuario, y registro de decisiones de diseño. Runbooks operativos en [docs/](#).